

Lab 04

Course: Software System Architecture

Lecturer: Mr. Chun Thavorac

Name: Kiv Sovannlyda

ID: p20240001

Record your results

Part A–B — Test results

Request	Status code	Notes
GET /v1/restaurants?limit=2	200	It returns the first 2 restaurants from the in-memory array
POST /v1/orders (valid)	201	The Order is created with the status “PLACED”
POST /v1/orders (restaurantId "a", items [])	400	Validation failed because the ID isn’t an int and the item array is empty
POST /v1/orders, restaurant 99	404	It throws NotFoundException because restaurant ID 99 doesn’t exist
GET /v1/orders/{id} (exists / missing)	200/404	It returns the order object if found or throws a NotFoundException if it’s missing
PATCH PLACED → COOKING	200	Successful state transition
PATCH PLACED → DELIVERED	409	Since jumping from DELIVERING state is invalid, it throws a ConflictException
POST with Idempotency-Key abc-123 (1st / 2nd)	201/200	The first request creates the order and the second returns the exact same order from memory without recreating it

Why does a mobile app on a bad network need an idempotency key? (one sentence)

A mobile app on a bad network needs an idempotency key to safely retry requests when connections drop without the risk of accidentally creating duplicate orders or double-charging the user.

API specification (copy into the portfolio)

Method	Path	Request body	Success	Error codes
GET	/v1/restaurants	(None)	200	(None)
POST	/v1/orders	{"restaurantId": number, "items": string[]}	201 (or 200)	400, 404
GET	/v1/orders/:id	(None)	200	404
PATCH	/v1/orders/:id	{"status": string}	200	400, 404, 409
POST	/v1/login	(None)	201	(None)
GET	/v1/me	(None)	200	401

Part C — CORS

Question	Answer
CORS error message in the console	Blocked: TypeError: Failed to fetch

Why curl works but the browser refuses	curl works but the browser refuse because the browser enforces the Same-Origin policy to protect users from malicious scripts, while curl is a direct command line tool that does not run scripts or enforce browser security rules
Why `origin: '*'` with credentials is a bad idea	It's a bad idea because it would allow any malicious website to make cross-origin requests using the user's active session cookies, which is why browsers block this combination entirely

Part D — Cookies

Question	Answer
Flags on the `sid` cookie	HttpOnly is checked which means true and SameSite is set to lax
Why `document.cookie` does not show `sid`	the HttpOnly flag specifically hides the cookie from client-side JavaScript to protect the session from XSS attacks
What happens after an API restart, and why	The API returns a 401 Unauthorized error because the session data is stored in a temporary in-memory map or sessions that is completely wiped when the server stops
What would happen with 3 API servers behind a load balancer	A user logged into server 1 would appear logged out if their next request is routed to server 2 or 3, because the in-memory maps are not shared between the separate servers